Active Directory Attack and Detection Lab

Nov 5, 2026 · @Anele

1. Overview

This project is a blue team home lab built around a Windows Server 2022 domain controller. From a Kali Linux attacker machine I simulated a realistic domain compromise, then traced each step in the Windows Security log to see what defenders can observe and how to alert on it. The attack chain covers enumeration, password spraying, and account creation with escalation to Domain Admin. The detection work extends this with custom Splunk rules and a Python SOC automation pipeline.

All activity was performed in a virtual lab on systems I own. Credentials visible in the evidence screenshots are redacted.

2. Objectives

- Build an Active Directory environment that produces realistic attack telemetry
- Simulate common identity-based attacks from an external attacker host
- Identify the Windows Event IDs each technique generates
- Turn those events into detection logic and map them to MITRE ATT&CK
- Document findings and hardening steps in a portfolio-ready format

3. Lab architecture

Role	System	Details
Attacker	Kali Linux, `192.168.10.30`	NetExec for enumeration and spraying
Domain controller	`DC01`, `192.168.10.10`	Windows Server 2022 (Build 20348), domain `corp.local`, SMB signing on, SMBv1 off, LDAP signing not enforced
Client	`CLIENT01`	Domain-joined workstation, visible as a computer object in LDAP
Hypervisor	Oracle VirtualBox	Lab network `192.168.10.x`

Directory objects: users `Administrator`, `Guest`, `krbtgt`, `john.smith`, `sarah.jones`, `mike.brown`; custom groups `IT Admins`, `HR Users`, `Finance Users`.

Logging: Security auditing on `DC01` recorded logon, account management, and privilege events (4624, 4625, 4672, 4720, 4728), which is the telemetry used throughout this project.

4. Phase 1: Enumeration

I enumerated `DC01` over SMB and LDAP with NetExec, authenticating as the built-in `Administrator` account (password redacted). NetExec returned `Pwn3d!`, confirming administrative access.

```
netexec smb  192.168.10.10 -u Administrator -p '<REDACTED>' --users
netexec smb  192.168.10.10 -u Administrator -p '<REDACTED>' --shares
netexec ldap 192.168.10.10 -u Administrator -p '<REDACTED>' --groups
netexec ldap 192.168.10.10 -u Administrator -p '<REDACTED>' --computers
```

Results

- **Users:** 6 accounts returned with password-last-set times, including the `krbtgt` service account.
- **Shares:** `ADMIN$`, `C$`, `NETLOGON`, and `SYSVOL` were readable and writable; `IPC$` was read-only.

- **Groups:** built-in groups plus `IT Admins`, `HR Users`, and `Finance Users`; `Administrators` had 3 members. NetExec does not support `--groups` over SMB and redirects to LDAP.
- **Computers:** 2 records, `DC01$` and `CLIENT01$`.

Observation: the LDAP banner reported `signing:None` and `channel binding: No TLS cert`, so LDAP signing and channel binding were not enforced on the domain controller.

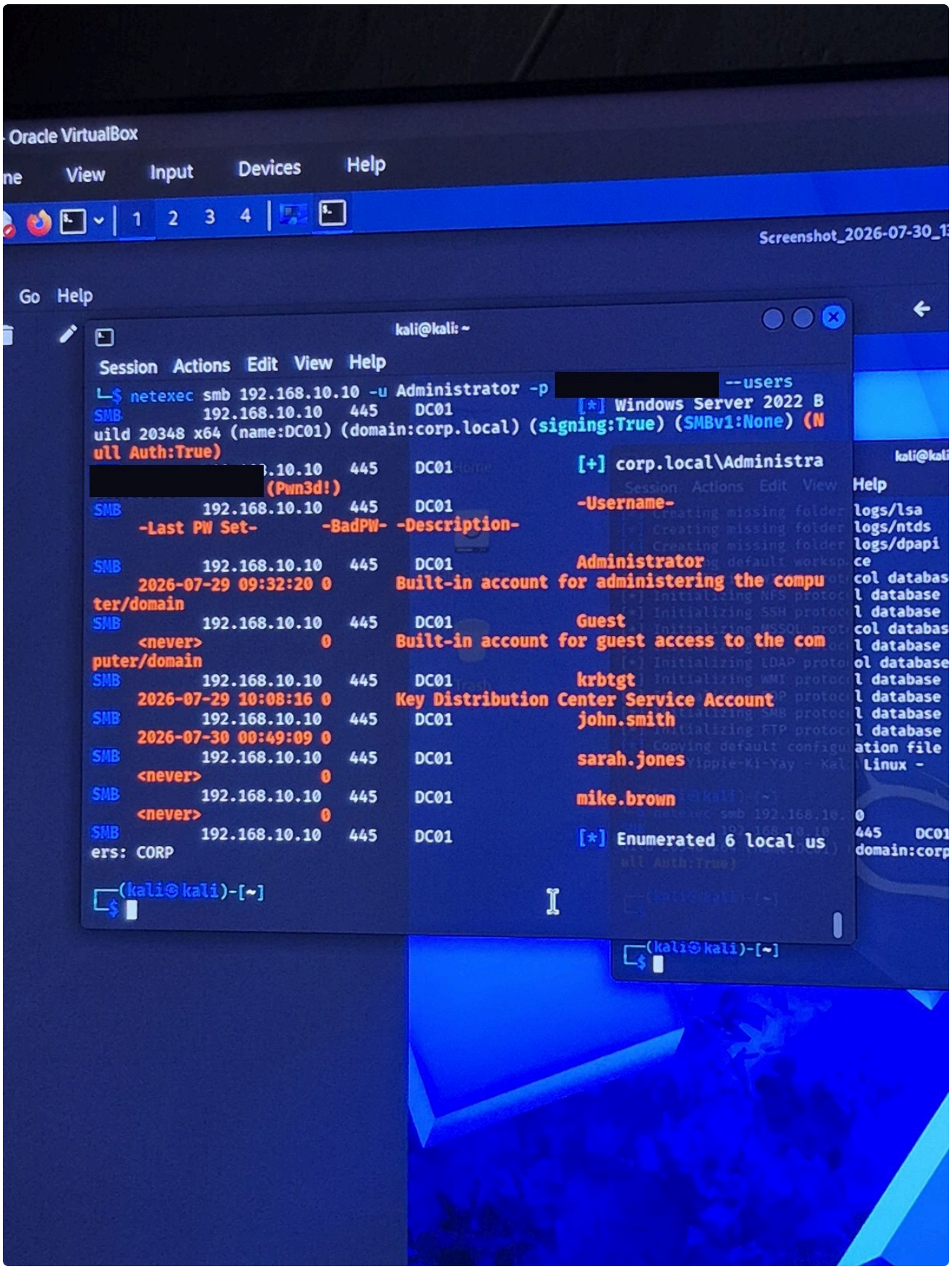

Oracle VirtualBox
View
Input
Devices
Help
Go
Help
kali@kali: ~
Session
Actions
Edit
View
Help
└─$ netexec smb 192.168.10.10 -u Administrator -p [redacted] --users
SMB 192.168.10.10 445 DC01 [*] Windows Server 2022 B
uild 20348 x64 (name:DC01) (domain:corp.local) (signing:True) (SMBv1:None) (N
ull Auth:True)
[redacted] 445 DC01 [+] corp.local\Administra
(Pwn3d!)
SMB 192.168.10.10 445 DC01 -Username-
-Last PW Set- -BadPW- -Description-
SMB 192.168.10.10 445 DC01 Administrator
2026-07-29 09:32:20 0 Built-in account for administering the compu
ter/domain
SMB 192.168.10.10 445 DC01 Guest
<never> 0 Built-in account for guest access to the com
puter/domain
SMB 192.168.10.10 445 DC01 krbtgt
2026-07-29 10:08:16 0 Key Distribution Center Service Account
SMB 192.168.10.10 445 DC01 john.smith
2026-07-30 00:49:09 0
SMB 192.168.10.10 445 DC01 sarah.jones
<never> 0
SMB 192.168.10.10 445 DC01 mike.brown
<never> 0
SMB 192.168.10.10 445 DC01 [*] Enumerated 6 local us
ers: CORP
(kali㉿kali)-[~]
$
Screenshot_2026-07-30_1
kali@kali
Help
logs/lsa
logs/ntds
logs/dpapi
ce
col databas
l database
l database
col databas
l database
ol database
l database
l database
l database
l database
ation file
Linux -
0
445 DC01
domain:corp

Figure 1: Domain users returned by NetExec over SMB.

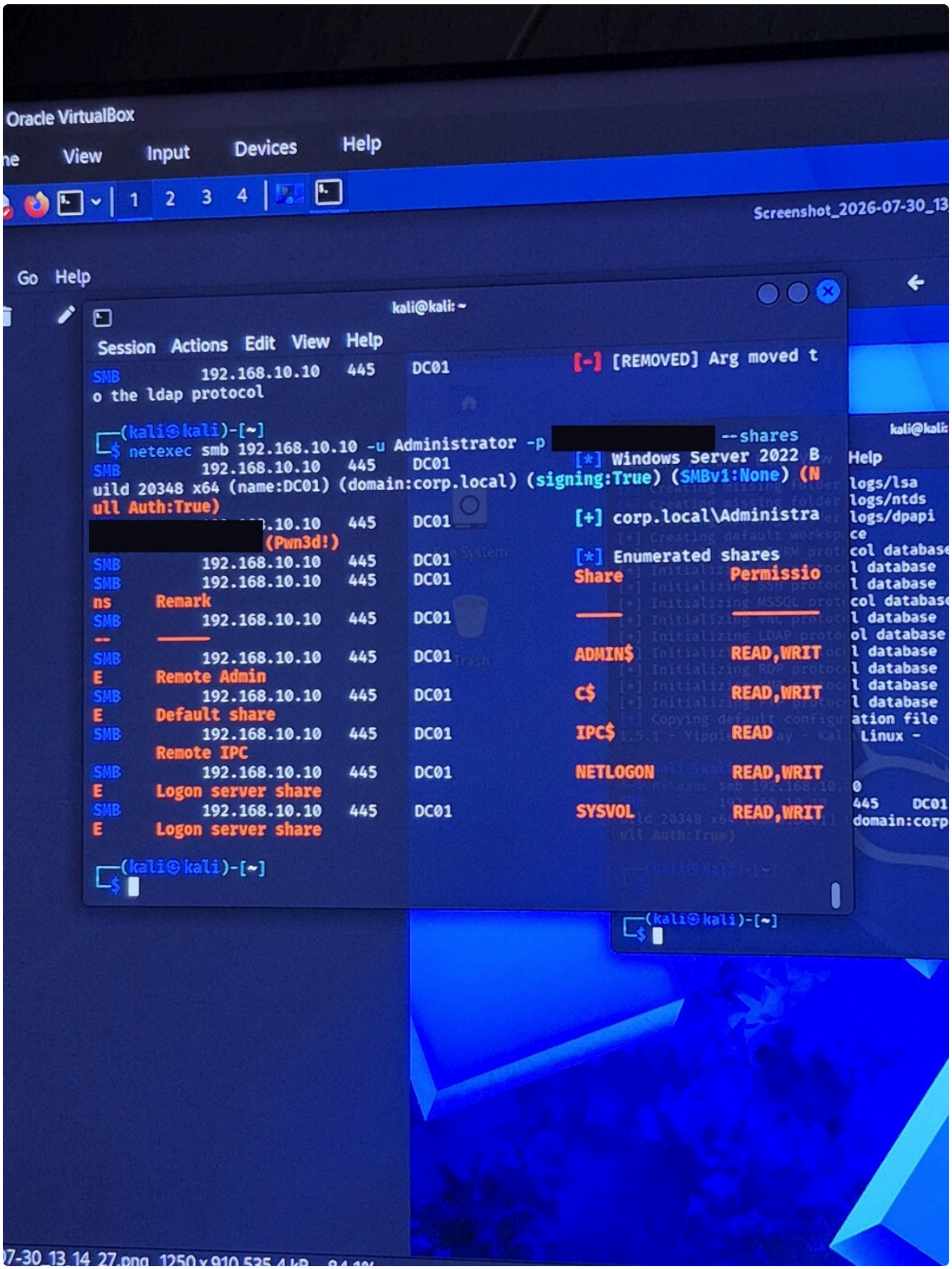

Oracle VirtualBox
View
Input
Devices
Help
Screenshot_2026-07-30_13
Go
Help
kali@kali: ~
Session
Actions
Edit
View
Help
SMB 192.168.10.10 445 DC01 [-] [REMOVED] Arg moved t
o the ldap protocol
(kali㉿kali)-[~]
$ netexec smb 192.168.10.10 -u Administrator -p [redacted] --shares
SMB 192.168.10.10 445 DC01 [*] Windows Server 2022 B
uild 20348 x64 (name:DC01) (domain:corp.local) (signing:True) (SMBv1:None) (N
ull Auth:True)
[redacted] 445 DC01 [+] corp.local\Administra
(Pwn3d!)
SMB 192.168.10.10 445 DC01 [*] Enumerated shares
SMB 192.168.10.10 445 DC01 Share Permissio
ns Remark
SMB 192.168.10.10 445 DC01 ----- -----
--
SMB 192.168.10.10 445 DC01 ADMIN$ READ,WRIT
E Remote Admin
SMB 192.168.10.10 445 DC01 C$ READ,WRIT
E Default share
SMB 192.168.10.10 445 DC01 IPC$ READ
Remote IPC
SMB 192.168.10.10 445 DC01 NETLOGON READ,WRIT
E Logon server share
SMB 192.168.10.10 445 DC01 SYSVOL READ,WRIT
E Logon server share
(kali㉿kali)-[~]
$
(kali㉿kali)-[~]
$
Help
logs/lsa
logs/ntds
logs/dpapi
ce
l database
l database
l database
l database
l database
l database
l database
l database
ation file
Linux -
445 DC01
domain:corp

Figure 2: Shares enumerated on `DC01` with their permissions.

5. Phase 2: Password spraying and detection

On 2026-07-30 I tried a single password against a username list, the classic spraying pattern that avoids locking accounts.

```
netexec smb 192.168.10.10 -u users.txt -p "Password123"
```

All three attempts returned `STATUS_LOGON_FAILURE`.

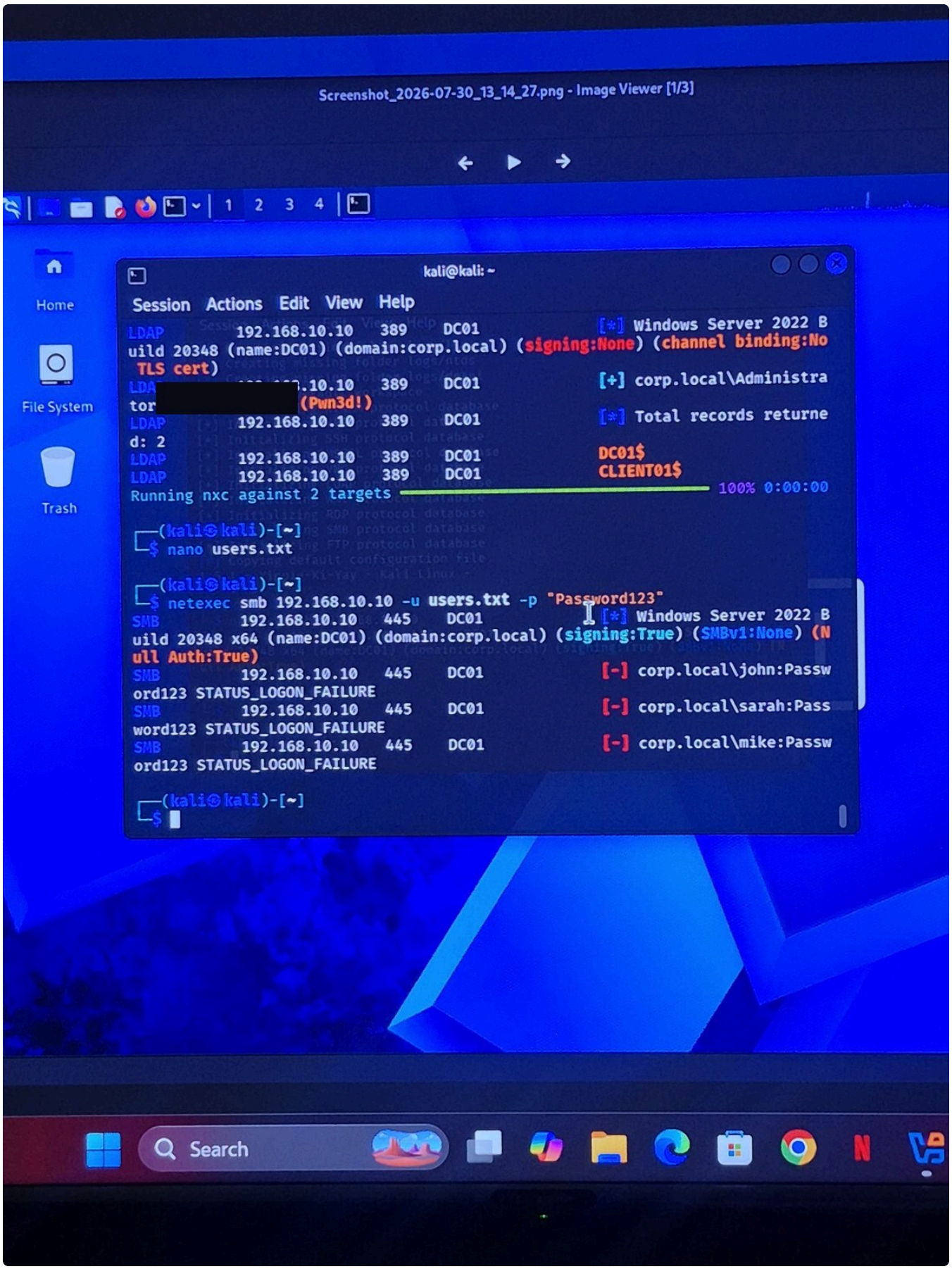

Screenshot_2026-07-30_13_14_27.png - Image Viewer [1/3]
Home
File System
Trash
kali@kali: ~
Session Actions Edit View Help
LDAP 192.168.10.10 389 DC01 [*] Windows Server 2022 B
uild 20348 (name:DC01) (domain:corp.local) (signing:None) (channel binding:No
TLS cert)
LDAP 192.168.10.10 389 DC01 [+] corp.local\Administra
tor (Pwn3d!)
LDAP 192.168.10.10 389 DC01 [*] Total records returne
d: 2
LDAP 192.168.10.10 389 DC01 DC01$
LDAP 192.168.10.10 389 DC01 CLIENT01$
Running nxc against 2 targets 100% 0:00:00
(kali㉿kali)-[~]
$ nano users.txt
(kali㉿kali)-[~]
$ netexec smb 192.168.10.10 -u users.txt -p "Password123"
SMB 192.168.10.10 445 DC01 [*] Windows Server 2022 B
uild 20348 x64 (name:DC01) (domain:corp.local) (signing:True) (SMBv1:None) (N
ull Auth:True)
SMB 192.168.10.10 445 DC01 [-] corp.local\john:Passw
ord123 STATUS_LOGON_FAILURE
SMB 192.168.10.10 445 DC01 [-] corp.local\sarah:Pass
word123 STATUS_LOGON_FAILURE
SMB 192.168.10.10 445 DC01 [-] corp.local\mike:Passw
ord123 STATUS_LOGON_FAILURE
(kali㉿kali)-[~]
$
Search

Figure 3: The spray from Kali and its three failed logons.

Detection: Event ID 4625. Filtering the Security log on `DC01` to 4625 showed three failures in the same second (13:13:09). The event details identify the source and target:

- Source network address `192.168.10.30` (the Kali host), source port `47852`
- Logon process `NtLmSsp`
- Account name `sarah`, domain `corp.local`

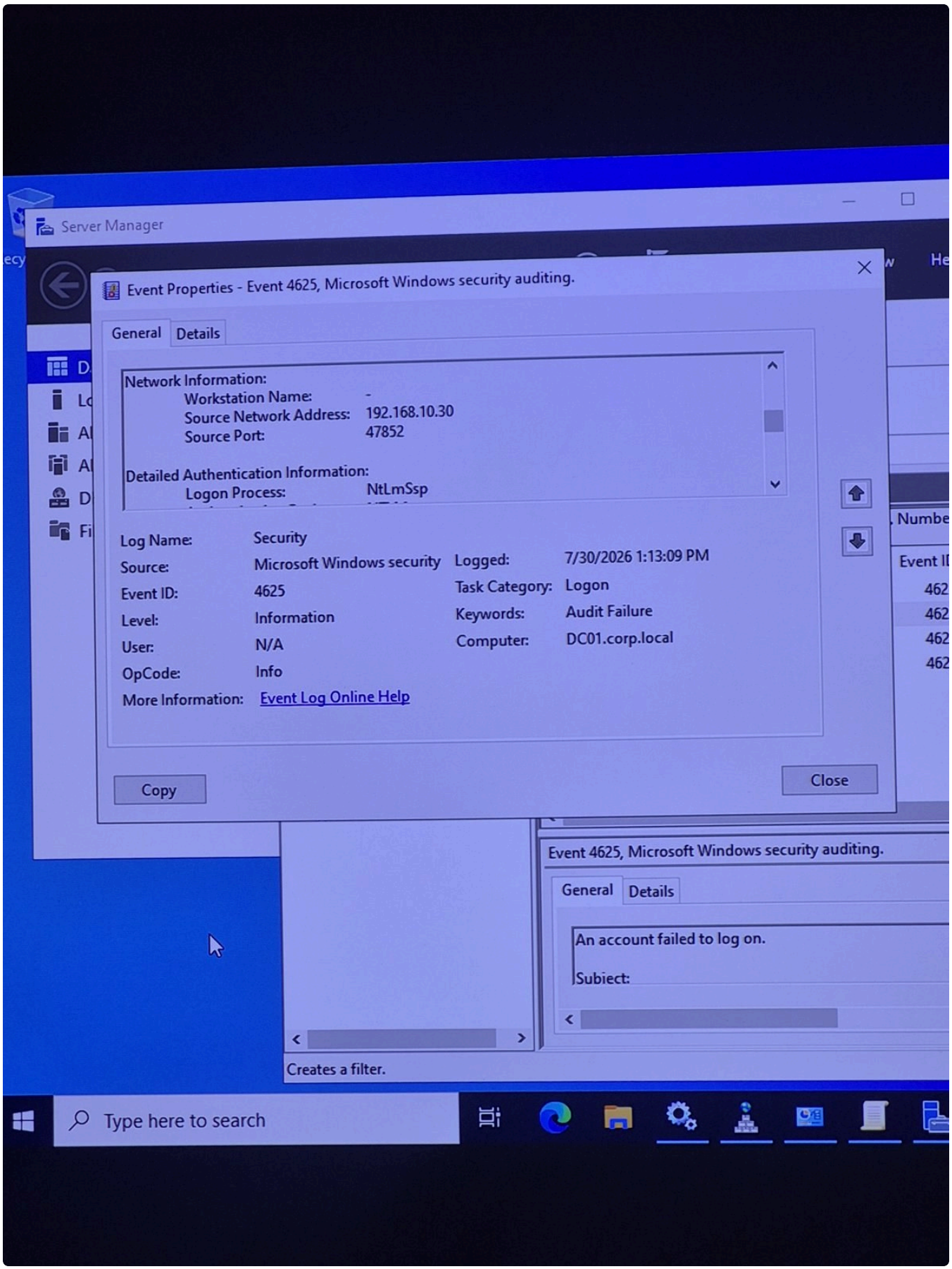

Server Manager
Event Properties - Event 4625, Microsoft Windows security auditing.
General
Details
Network Information:
Workstation Name: -
Source Network Address: 192.168.10.30
Source Port: 47852
Detailed Authentication Information:
Logon Process: NtLmSsp
Log Name: Security
Source: Microsoft Windows security
Logged: 7/30/2026 1:13:09 PM
Event ID: 4625
Task Category: Logon
Level: Information
Keywords: Audit Failure
User: N/A
Computer: DC01.corp.local
OpCode: Info
More Information: Event Log Online Help
Copy
Close
Event 4625, Microsoft Windows security auditing.
General
Details
An account failed to log on.
Subject:
Creates a filter.
Type here to search

Figure 4: Event 4625 details showing the attacker IP and logon process.

6. Phase 3: Account creation and privilege escalation

On 2026-08-01, using the `Administrator` session, a new domain account was created and added to `Domain Admins`. Each step is recorded on `DC01`:

Time	Event ID	What it shows
16:34:08	4624	Network logon (Type 3) with an elevated token
16:52:34	4720	`CORP\Administrator` (Logon ID `0x3F604`) created `CORP\test.user`
16:54:56	4728	The same Logon ID added `CN=Test User,OU=Employees,DC=corp,DC=local` to `CORP\Domain Admins`
16:56:08	4672	Special privileges assigned, including `SeDebugPrivilege`, `SeBackupPrivilege`, `SeRestorePrivilege`, `SeTakeOwnershipPrivilege`, and `SeLoadDriverPrivilege`

Because the 4720 and 4728 events share one Logon ID, account creation and escalation can be correlated into a single alert.

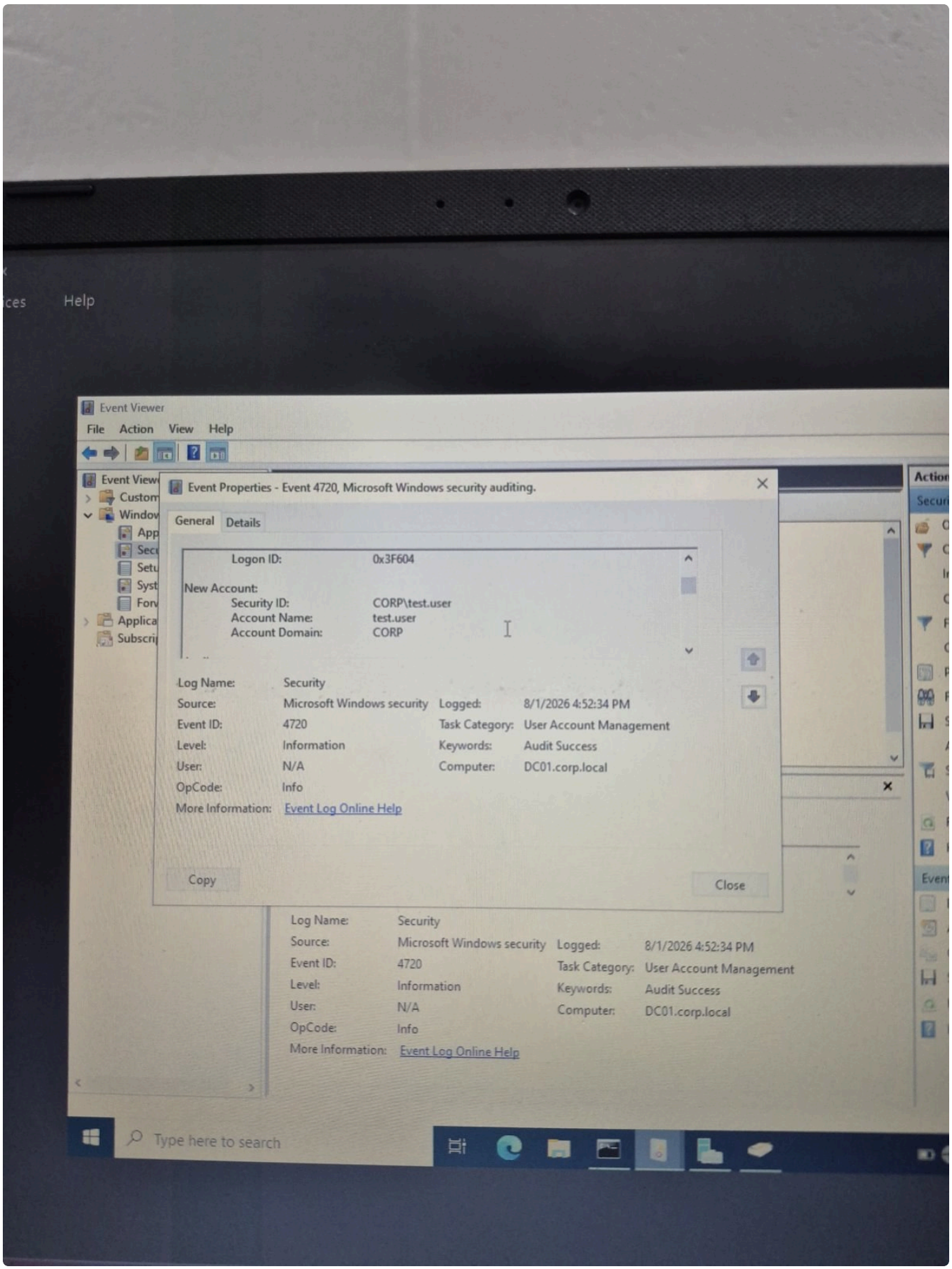

Help
Event Viewer
File Action View Help
Event Properties - Event 4720, Microsoft Windows security auditing.
General Details
Logon ID: 0x3F604
New Account:
Security ID: CORP\test.user
Account Name: test.user
Account Domain: CORP
Log Name: Security
Source: Microsoft Windows security
Logged: 8/1/2026 4:52:34 PM
Event ID: 4720
Task Category: User Account Management
Level: Information
Keywords: Audit Success
User: N/A
Computer: DC01.corp.local
OpCode: Info
More Information: Event Log Online Help
Copy
Close
Type here to search

Figure 5: Event 4720, user account `test.user` created.

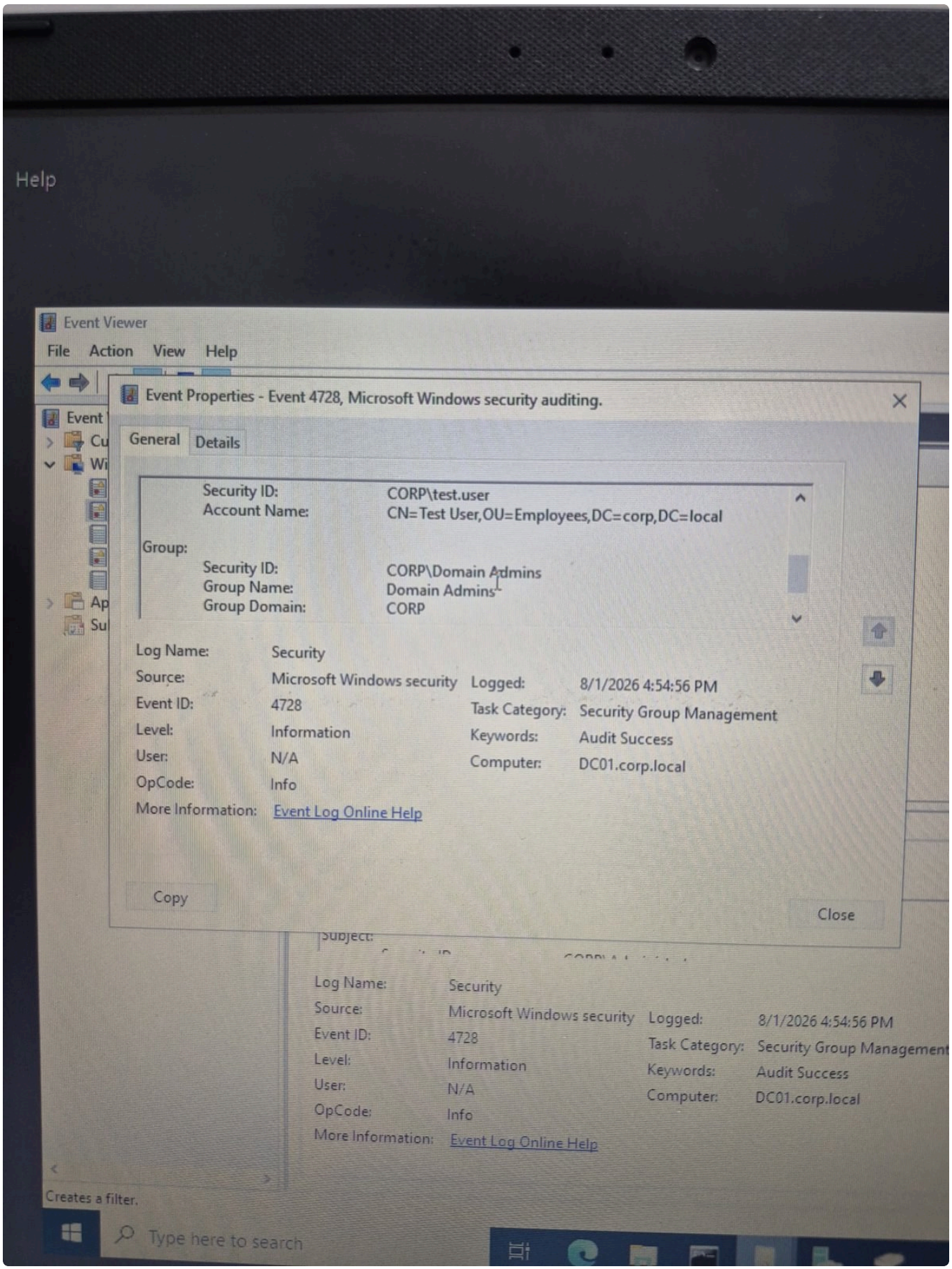

Help
Event Viewer
File Action View Help
Event Properties - Event 4728, Microsoft Windows security auditing.
General Details
Security ID: CORP\test.user
Account Name: CN=Test User,OU=Employees,DC=corp,DC=local
Group:
Security ID: CORP\Domain Admins
Group Name: Domain Admins
Group Domain: CORP
Log Name: Security
Source: Microsoft Windows security
Logged: 8/1/2026 4:54:56 PM
Event ID: 4728
Task Category: Security Group Management
Level: Information
Keywords: Audit Success
User: N/A
Computer: DC01.corp.local
OpCode: Info
More Information: Event Log Online Help
Copy
Close
Creates a filter.
Type here to search

Figure 6: Event 4728, member added to Domain Admins.

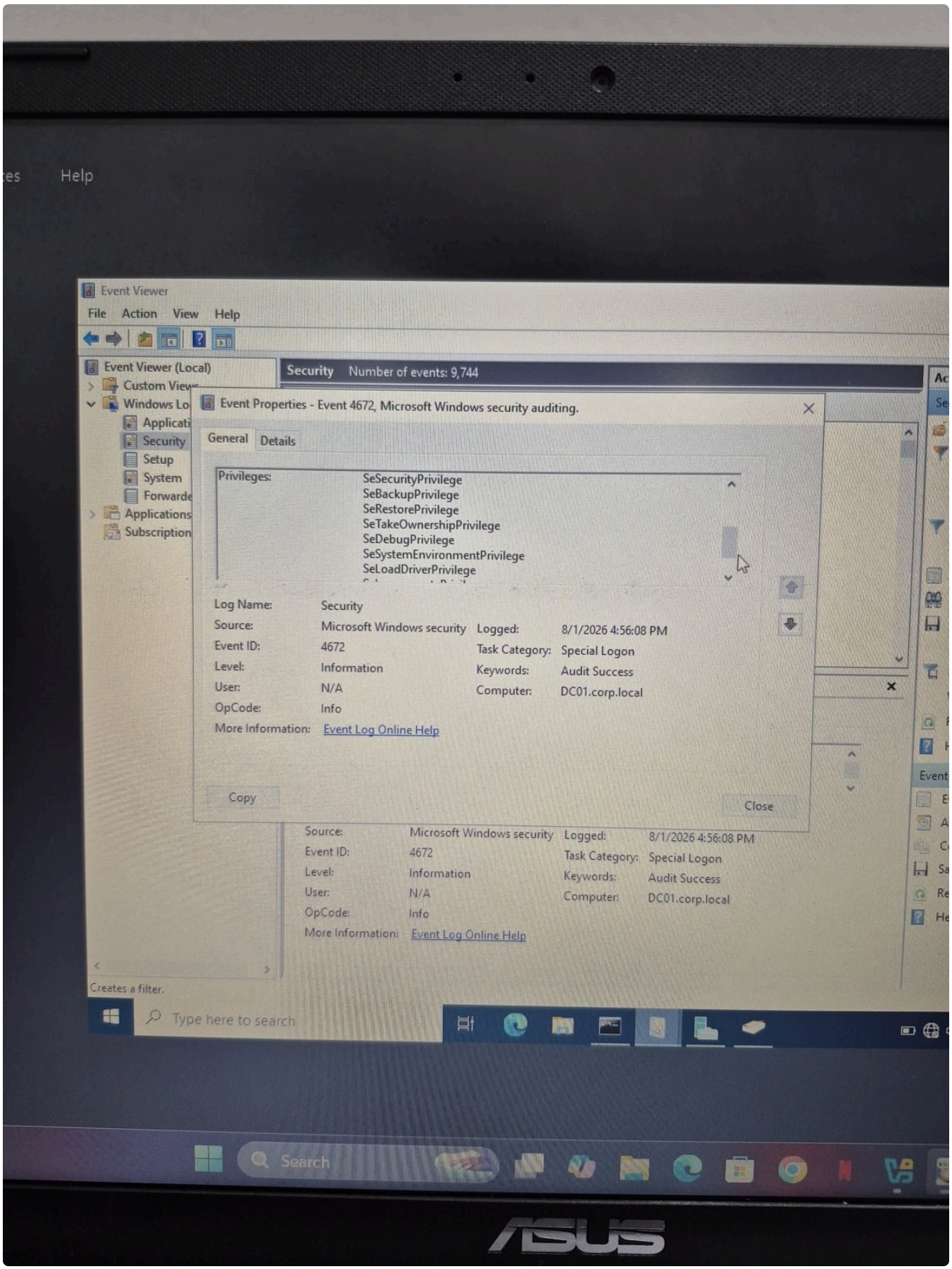

Help
Event Viewer
File Action View Help
Event Viewer (Local)
Custom Views
Windows Logs
Application
Security
Setup
System
Forwarded Events
Applications and Services Logs
Subscriptions
Security Number of events: 9,744
Event Properties - Event 4672, Microsoft Windows security auditing.
General Details
Privileges: SeSecurityPrivilege
SeBackupPrivilege
SeRestorePrivilege
SeTakeOwnershipPrivilege
SeDebugPrivilege
SeSystemEnvironmentPrivilege
SeLoadDriverPrivilege
Log Name: Security
Source: Microsoft Windows security
Logged: 8/1/2026 4:56:08 PM
Event ID: 4672
Task Category: Special Logon
Level: Information
Keywords: Audit Success
User: N/A
Computer: DC01.corp.local
OpCode: Info
More Information: Event Log Online Help
Copy
Close
Source: Microsoft Windows security
Logged: 8/1/2026 4:56:08 PM
Event ID: 4672
Task Category: Special Logon
Level: Information
Keywords: Audit Success
User: N/A
Computer: DC01.corp.local
OpCode: Info
More Information: Event Log Online Help
Creates a filter.
Type here to search
Search
ASUS

Figure 7: Event 4672, sensitive privileges assigned to a new logon.

7. Detection engineering and SOC automation

Beyond the Event Viewer analysis above, the lab was extended into a detection and response workflow:

- **Identity attack detection:** five attacks were simulated in the Active Directory and Splunk environment: password spraying, brute force, account lockout abuse, Kerberoasting, and AS-REP roasting. I wrote custom SPL detection rules and tuned them with discriminating logic to reduce false positives.
- **Documentation:** GitHub-ready README files, Word write-ups, and Windows Event ID reference tables.
- **SOC automation:** a Python pipeline with a Flask webhook entry point and three steps, risk scoring (`risk_scoring.py`), incident summary generation (`incident_summary.py`), and Slack notification (`notifier.py`).

8. Detection logic

Behavior	Source events	Alert logic
Password spraying	4625	3 or more failures from one source IP against multiple distinct accounts within 60 seconds
Rogue admin creation	4720 then 4728	Account created and added to a privileged group by the same Logon ID within minutes
Privileged group change	4728	Any addition to `Domain Admins`, `Enterprise Admins`, or `Administrators` (high severity)
Unexpected privileged logon	4672	Special privileges assigned to a new or non-standard account
Remote admin activity	4624 (Type 3)	Network logon with an elevated token from a non-admin workstation

9. Findings and hardening

- **LDAP signing and channel binding were not enforced.** Require LDAP signing and enable channel binding to reduce NTLM relay risk.
- **`Administrator` allowed remote SMB and LDAP enumeration.** Restrict the built-in account, use tiered admin accounts, and enforce strong, unique passwords.
- **Spray detection depends on 4625 volume.** Pair threshold alerts with an account lockout policy.
- **Domain Admins changes need real-time alerting.** Event 4728 was the clearest signal in the escalation chain.

10. MITRE ATT&CK mapping

Technique	ID
Account Discovery: Domain Account	T1087.002
Permission Groups Discovery: Domain Groups	T1069.002
Network Share Discovery	T1135
Remote System Discovery	T1018
Brute Force: Password Spraying	T1110.003
Valid Accounts: Domain Accounts	T1078.002
Create Account: Domain Account	T1136.002
Account Manipulation	T1098

11. Limitations and next steps

- The spray used `john`, `sarah`, and `mike`, but the real accounts are `john.smith`, `sarah.jones`, and `mike.brown`. Re-running with exact account names would exercise the bad-password path rather than non-existent users and give more realistic 4625 data.
- Turn the Phase 3 detections (4720, 4728, 4672) into saved searches alongside the existing identity-attack rules.

- Expand to eight attacks and generate benign traffic to measure a credible false-positive baseline.

12. Skills demonstrated

- Active Directory enumeration and attack simulation (NetExec, SMB, LDAP, NTLM)
- Windows Security log analysis and Event ID interpretation
- Detection engineering with Splunk SPL and MITRE ATT&CK mapping
- Python automation for SOC workflows (Flask, Slack integration)
- Technical documentation for GitHub and portfolio use

Appendix: Windows Event ID reference

Event ID	Meaning	Seen in this lab
4625	An account failed to log on	Password spray
4624	An account was successfully logged on	Network logon before escalation
4720	A user account was created	`test.user` created
4728	A member was added to a security-enabled global group	`test.user` added to Domain Admins
4672	Special privileges assigned to new logon	Sensitive privileges on `DC01`